

200 Cybersecurity Internship Interview Questions (with Answers)

For ₹5,000 – ₹1,00,000/month
Internships | Freshers → Job-Ready

How to use this guide:

- Split is roughly 50% theory/concept, 50% practical/hands-on/scenario questions — this mirrors how real internship interviews (TCS, startups, MNCs, security firms, unpaid-to-₹1L/month roles) are actually conducted.
 - Don't memorize answers word-for-word. Understand the *why*. Interviewers immediately notice cramming vs understanding.
 - If you can confidently answer 150+/200 in your own words and demonstrate 2–3 tools live (Nmap, Wireshark, Burp Suite), you are genuinely ready for a ₹15k–₹50k/month internship, and a strong portfolio (GitHub + TryHackMe/HackTheBox profile) pushes you toward ₹50k+ and full-time offers around ₹2L+ (₹2,00,000) package.
 - Practice out loud, like you're explaining to an interviewer, not reading.
-

SECTION 1: Networking Fundamentals (Q1–Q20)

1. What is the OSI model? Name all 7 layers. A conceptual 7-layer framework describing how data travels across a network: Physical, Data Link, Network, Transport, Session, Presentation, Application (mnemonic: "Please Do Not Throw Sausage Pizza Away").

2. What is the TCP/IP model and how does it differ from OSI? A 4-layer practical model (Network Access, Internet, Transport, Application) that's actually implemented in real networks; OSI is theoretical/teaching-focused with 7 layers.

3. Difference between TCP and UDP? TCP is connection-oriented, reliable, uses handshake, ordered delivery (e.g., HTTP, email). UDP is connectionless, faster, no guarantee of delivery (e.g., DNS, video streaming, gaming).

4. Explain the TCP 3-way handshake. SYN (client requests connection) → SYN-ACK (server acknowledges + responds) → ACK (client confirms). This establishes a reliable connection before data transfer.

5. What is a subnet mask and why is it used? It divides an IP address into network and host portions, allowing networks to be segmented for organization and security (e.g., 255.255.255.0).

6. What is NAT (Network Address Translation)? Translates private internal IPs to a public IP so multiple devices can share one external IP address, also hiding internal network structure.

7. What is a firewall and how does it work? A security device/software that filters incoming/outgoing traffic based on defined rules (IP, port, protocol) to block unauthorized access.

8. Difference between a firewall, IDS, and IPS? Firewall blocks/allows traffic based on rules. IDS (Intrusion Detection System) monitors and alerts on suspicious activity but doesn't block. IPS (Intrusion Prevention System) monitors AND actively blocks threats in real time.

9. What is DNS and how does DNS resolution work? Domain Name System translates human-readable domains (google.com) to IP addresses. Query goes: browser → resolver → root server → TLD server → authoritative server → IP returned.

10. What is DNS spoofing/cache poisoning? An attacker corrupts DNS cache with fake records, redirecting users to malicious sites instead of the legitimate one.

11. What is a VPN and how does it secure communication? Virtual Private Network creates an encrypted tunnel between the user and a server, hiding traffic from ISPs/attackers and masking the real IP.

12. What ports are used by HTTP, HTTPS, FTP, SSH, DNS, SMTP, Telnet, RDP? HTTP-80, HTTPS-443, FTP-21, SSH-22, DNS-53, SMTP-25, Telnet-23, RDP-3389.

13. What is the difference between a hub, switch, and router? Hub broadcasts data to all ports (no intelligence). Switch sends data only to the intended device using MAC addresses. Router connects different networks and routes data using IP addresses.

14. What is ARP and how does ARP spoofing work? Address Resolution Protocol maps IP to MAC addresses. ARP spoofing sends fake ARP replies to associate the attacker's MAC with a victim's IP, enabling man-in-the-middle attacks.

15. What is a proxy server? An intermediary between client and server that can provide anonymity, caching, content filtering, or load balancing.

16. What is a VLAN and why is it used? Virtual LAN logically segments a physical network into separate broadcast domains for security and traffic management, without needing separate physical hardware.

17. What is port scanning and why do attackers/pentesters do it?

Scanning a target's open ports to discover running services — used by attackers for recon and by pentesters to find vulnerable/exposed services (tool: Nmap).

18. What is a MAC address vs IP address? MAC is a hardware-level, physical, unique identifier of a network interface. IP is a logical, software-assigned address that can change.

19. What is a man-in-the-middle (MITM) attack? Attacker secretly intercepts and possibly alters communication between two parties who believe they're talking directly to each other.

20. What is packet sniffing? Capturing data packets traveling over a network to analyze or steal information (tool: Wireshark). Legal for defenders on their own network; illegal otherwise.

SECTION 2: Operating Systems & Linux (Q21–Q40)

21. Why is Linux important for cybersecurity roles? Most servers, security tools (Kali, Nmap, Metasploit), and cloud infrastructure run on Linux; command-line fluency is mandatory for SOC/pentest work.

22. How do you check running processes in Linux? `ps aux` or `top/htop`.

23. How do you find open ports on a Linux machine? `netstat -tulnp` or `ss -tulnp`.

24. What command changes file permissions in Linux? `chmod` (e.g., `chmod 755 file.sh`); ownership changed with `chown`.

25. Explain Linux file permission numbers (e.g., 755, 644). Each digit = owner/group/others; 4=read, 2=write, 1=execute, summed (7=rwx, 5=r-x, 4=r--).

26. How do you view live logs in Linux? `tail -f /var/log/syslog` (or relevant log file).

27. What is the difference between a process and a thread? A process is an independent running program with its own memory space; a thread is a lightweight unit of execution within a process sharing memory with other threads of the same process.

28. What is sudo and why is it a security concern if misconfigured? `sudo` grants temporary elevated (root) privileges; misconfigured sudoers files can allow privilege escalation to full root access by unauthorized users.

29. What's the difference between Windows Event Viewer and Linux syslog? Both log system/security events; Event Viewer is Windows' GUI-based structured logging (Security, System, Application logs), syslog is Linux's plain-text centralized logging system.

30. What is a rootkit? Malicious software designed to gain and hide privileged (root/admin) access on a system while evading detection.

31. How do you find a specific string inside multiple files in Linux? `grep -r "string" /path/`.

32. What is chroot jail? A technique that restricts a process to a specific directory tree, isolating it from the rest of the filesystem for security.

33. What is the purpose of /etc/passwd and /etc/shadow in Linux? `/etc/passwd` stores user account info (not passwords); `/etc/shadow` stores hashed passwords and is restricted to root.

34. What is privilege escalation? Exploiting a bug/misconfiguration to gain higher-level access than originally granted (vertical: user→admin, horizontal: user→another user).

35. How would you check which users are logged into a Linux system?

`who` or `w`.

36. What is Windows Registry and why does it matter in forensics? A

hierarchical database storing OS/app configuration settings; forensic investigators examine it for evidence of installed programs, USB history, persistence mechanisms of malware.

37. What's the difference between a Windows Domain and Workgroup?

Domain = centrally managed by a server (Active Directory) with unified authentication; Workgroup = decentralized, each machine manages its own accounts.

38. What is Active Directory and why is it a major attack target? Microsoft's

directory service managing users/permissions across a network; it's a huge target because compromising it (e.g., via Kerberoasting) can grant control over an entire organization.

39. How do you kill a process in Linux by PID? `kill -9 <PID>`.

40. What's the difference between a virtual machine and a container (e.g.,

Docker)? VM virtualizes entire hardware+OS (heavier, fully isolated); container shares the host OS kernel but isolates the application layer (lightweight, faster).

SECTION 3: Core Security Fundamentals (Q41–Q55)

41. What is the CIA Triad? Confidentiality (data only accessible to authorized users), Integrity (data isn't tampered with), Availability (systems/data accessible when needed) — the foundation of all security.

42. What is the difference between authentication and authorization?

Authentication verifies *who you are* (login/password, biometrics); authorization determines *what you're allowed to do* once verified.

43. What is multi-factor authentication (MFA)? Requiring 2+ independent proofs of identity (something you know/have/are) — e.g., password + OTP — to significantly reduce account takeover risk.

44. What is the difference between a vulnerability, a threat, and a risk?

Vulnerability = a weakness. Threat = a potential danger that could exploit it.

Risk = the likelihood + impact of that threat exploiting the vulnerability.

45. What is social engineering? Give 3 examples. Manipulating people (not systems) into revealing info/access. Examples: phishing, pretexting (impersonating IT support), baiting (infected USB left in parking lot).

46. What is phishing vs spear phishing vs whaling? Phishing = mass generic fraudulent emails. Spear phishing = targeted at a specific person/org using personal details. Whaling = spear phishing aimed at executives/high-value targets.

47. What is a zero-day vulnerability? A previously unknown flaw with no patch available yet — attackers exploit it before defenders even know it exists.

48. What is defense in depth? Using multiple layered security controls (firewall + IDS + endpoint protection + access control etc.) so if one layer fails, others still protect the system.

49. What is the principle of least privilege? Users/processes should only get the minimum access needed to perform their job — reduces blast radius if compromised.

50. What's the difference between symmetric and asymmetric encryption?

Symmetric uses one shared key for encryption/decryption (fast, e.g., AES). Asymmetric uses a public/private key pair (slower, e.g., RSA), used for key exchange and digital signatures.

51. What is hashing, and how is it different from encryption? Hashing is a one-way function converting data into a fixed-size irreversible value (used for integrity/password storage); encryption is reversible with a key (used for confidentiality).

52. Name common hashing algorithms and which are considered broken.

MD5 and SHA-1 are broken/weak (collision attacks); SHA-256 and SHA-3 are currently secure.

53. What is a security policy and why does an organization need one?

A formal document defining rules for acceptable use, access control, incident response etc. — sets the baseline standard everyone must follow.

54. What is patch management and why is it critical?

The process of regularly updating software/systems to fix known vulnerabilities — most breaches exploit *known, unpatched* flaws, not zero-days.

55. What is a honeypot?

A decoy system intentionally left vulnerable to attract attackers, allowing defenders to study attack techniques without risking real assets.

SECTION 4: Cryptography (Q56–Q70)

56. What is a digital signature and what does it guarantee?

Data signed with a private key, verifiable with the public key — guarantees authenticity (who sent it) and integrity (not altered).

57. What is a digital certificate and what is its role in HTTPS? A file issued by a Certificate Authority binding a public key to an identity (domain), enabling browsers to trust and encrypt connections via SSL/TLS.

58. Explain SSL/TLS handshake briefly. Client and server agree on protocol version/cipher, server sends its certificate, a session key is exchanged/derived (often via asymmetric crypto), then symmetric encryption is used for the actual session.

59. Difference between SSL and TLS? TLS is the modern, more secure successor to SSL; SSL is deprecated/considered insecure, though "SSL certificate" is still used colloquially to mean TLS certificates.

60. What is a salt in password hashing and why is it used? A random value added to a password before hashing so identical passwords produce different hashes — defeats rainbow table attacks.

61. What is PKI (Public Key Infrastructure)? The overall system of certificate authorities, digital certificates, and public/private key management that enables secure identity verification and encryption.

62. What is a brute-force attack vs a dictionary attack? Brute-force tries every possible combination of characters; dictionary attack tries a curated list of likely passwords/words — dictionary is faster if the password is common.

63. What is a rainbow table attack? Using precomputed tables of hash values to reverse-lookup a password's plaintext quickly, defeated by salting.

64. What is end-to-end encryption? Only the sender and recipient can read the message — not even the service provider carrying it (e.g., WhatsApp, Signal).

65. What is steganography? Hiding data within another file (image, audio) so its existence itself is concealed, unlike encryption which hides the *content* but not the presence of data.

66. What is the difference between encoding, encryption, and hashing?

Encoding transforms data format for compatibility (reversible, no key, e.g., Base64) — not security. Encryption is reversible with a key. Hashing is one-way, irreversible.

67. What is a Man-in-the-Middle attack against SSL/TLS, and how is it mitigated?

Attacker intercepts the encrypted session, often via fake certificates; mitigated by certificate pinning, HSTS, and verifying CA trust chains.

68. What is AES and why is it widely used?

Advanced Encryption Standard — a fast, strong symmetric block cipher (128/192/256-bit keys), industry standard for encrypting data at rest and in transit.

69. What does "PFS" (Perfect Forward Secrecy) mean?

Even if a server's private key is compromised later, past session communications can't be decrypted because session keys are generated uniquely per session.

70. What is a certificate authority (CA) and what happens if one is

compromised? A trusted entity that issues digital certificates; if compromised, attackers can issue fraudulent certificates, undermining trust across the entire web for sites using that CA.

SECTION 5: Web Application Security / OWASP Top 10 (Q71–Q95)

71. What is OWASP and why is the OWASP Top 10 important?

A nonprofit that publishes the industry-standard list of the 10 most critical web application security risks — used as a baseline checklist by security teams worldwide.

72. What is SQL Injection? Give an example payload. Injecting malicious SQL through user input to manipulate a database query. Example: `' OR '1'='1' --` in a login field can bypass authentication.

73. How do you prevent SQL Injection? Use parameterized queries/prepared statements, input validation, ORM frameworks, and least-privilege database accounts.

74. What is Cross-Site Scripting (XSS)? Name its 3 types. Injecting malicious scripts into a webpage viewed by others. Types: Stored (saved on server), Reflected (via URL/request), DOM-based (client-side JS manipulation).

75. How do you prevent XSS? Output encoding/escaping, input validation, Content Security Policy (CSP), using frameworks that auto-escape output (React, Angular).

76. What is Cross-Site Request Forgery (CSRF)? Tricking an authenticated user's browser into submitting an unwanted request (e.g., transferring money) without their knowledge, exploiting their active session.

77. How do you prevent CSRF? Anti-CSRF tokens (unique per session/form), SameSite cookie attribute, verifying the Referer/Origin header.

78. What is broken authentication? Flaws in login/session management (weak passwords allowed, predictable session IDs, no logout) that let attackers compromise accounts.

79. What is insecure direct object reference (IDOR)? When an app exposes internal object references (e.g., `?userid=123`) without checking authorization, letting attackers access others' data by changing the ID.

80. What is Security Misconfiguration? Leaving default credentials, unnecessary services, verbose error messages, or unpatched software exposed — one of the most common real-world breach causes.

81. What is Server-Side Request Forgery (SSRF)? Tricking a server into making unintended requests (often to internal/private resources) on the attacker's behalf.

82. What is a file upload vulnerability? Insufficient validation on uploaded files lets an attacker upload a malicious file (e.g., a web shell) and execute it on the server.

83. What is command injection? Injecting OS-level commands through vulnerable input fields that get passed unsanitized to the system shell.

84. What is a Web Shell? A malicious script uploaded to a compromised server that gives the attacker remote command execution through a web interface.

85. What is session hijacking? Stealing/predicting a valid session token/cookie to impersonate an authenticated user without needing their password.

86. What are secure HTTP headers and name 3 important ones. Response headers that enforce security policies in the browser. Examples: `Content-Security-Policy` (blocks XSS), `X-Frame-Options` (prevents clickjacking), `Strict-Transport-Security` (forces HTTPS).

87. What is clickjacking? Tricking a user into clicking something different from what they perceive by overlaying invisible malicious elements over a legitimate page (often via iframes).

88. What is an API and what security risks are unique to APIs? A set of rules letting applications communicate; risks include broken object-level authorization, lack of rate limiting, excessive data exposure, and weak authentication.

89. What is JWT (JSON Web Token) and a common vulnerability with it? A compact token format used for authentication/authorization. Common flaw: accepting the "none" algorithm or weak signing secrets, letting attackers forge valid tokens.

90. What is directory/path traversal? Manipulating file paths (e.g., `../../../../etc/passwd`) to access files outside the intended directory.

91. What is a WAF (Web Application Firewall)? A security layer that filters/monitors HTTP traffic to a web app, blocking common attacks like SQLi and XSS before they reach the application.

92. What is XML External Entity (XXE) injection? Exploiting XML parsers that process external entity references, potentially exposing internal files or enabling SSRF.

93. What is subdomain takeover? When a subdomain points (via DNS CNAME) to a service that's no longer active/claimed, letting an attacker claim that service and control content served on the subdomain.

94. What is rate limiting and why does it matter for security? Restricting the number of requests a user/IP can make in a given time — prevents brute-force login attempts, API abuse, and DoS.

95. What is the difference between authentication bypass and privilege escalation on a web app? Authentication bypass skips login entirely (exploiting a flaw); privilege escalation means you're logged in as a low-privilege user but gain higher access than intended.

SECTION 6: Practical Tools — Nmap, Wireshark, Burp Suite (Q96–Q115)

96. What is Nmap used for? Network discovery and port scanning tool — identifies live hosts, open ports, running services, and OS fingerprinting.

97. Write an Nmap command to scan all ports on a target. `nmap -p- 192.168.1.10`

98. What does `nmap -sV` do? Performs service/version detection on open ports.

99. What does `nmap -A` do? Aggressive scan: enables OS detection, version detection, script scanning, and traceroute together.

100. What is the difference between a TCP connect scan and a SYN scan in Nmap? Connect scan (`-sT`) completes the full 3-way handshake (noisier, logged). SYN scan (`-sS`, "stealth scan") sends SYN and doesn't complete the handshake, making it faster and less detectable.

101. How do you scan for a specific port range with Nmap? `nmap -p 1-1000 192.168.1.10`

102. What is Wireshark used for? A packet-capture and network protocol analyzer tool used to inspect traffic in detail for troubleshooting or detecting malicious activity.

103. How do you filter for only HTTP traffic in Wireshark? Type `http` in the display filter bar.

104. How would you find plaintext credentials in a Wireshark capture?

Filter for `http.request.method == "POST"` and inspect the packet data, or use `Follow > HTTP Stream` to see the full conversation.

105. What is Burp Suite used for? An intercepting proxy tool for testing web applications — capturing/modifying HTTP requests, scanning for vulnerabilities, automating attacks (Repeater, Intruder).

106. What is the "Repeater" tab in Burp Suite used for? Manually resending and modifying a captured HTTP request repeatedly to test how the server responds to different inputs.

107. What is the "Intruder" tab in Burp Suite used for? Automating attacks by injecting payloads (e.g., password lists, fuzzing values) into specific request parameters.

108. How do you configure your browser to intercept traffic through Burp Suite? Set the browser's proxy to 127.0.0.1:8080 (Burp's default listener) and install Burp's CA certificate to intercept HTTPS traffic.

109. What is Metasploit used for? An exploitation framework containing a database of known exploits, payloads, and post-exploitation modules used for penetration testing.

110. What is Nikto? A web server vulnerability scanner that checks for outdated software, dangerous files, and common misconfigurations.

111. What is John the Ripper / Hashcat used for? Password cracking tools that attempt to recover plaintext passwords from captured hashes using dictionary, brute-force, or rule-based attacks.

112. What is a "SIEM" tool and name one example. Security Information and Event Management — aggregates and correlates logs from across an organization for detection/analysis. Examples: Splunk, IBM QRadar, Microsoft Sentinel, ELK Stack.

113. What is tcpdump? A command-line packet analyzer (similar to Wireshark) used to capture network traffic directly from the terminal.

114. What is the purpose of a vulnerability scanner like Nessus or OpenVAS? Automatically scans systems/networks against a database of known vulnerabilities (CVEs) and generates a report with severity ratings.

115. What is the difference between active and passive reconnaissance? Active recon directly interacts with the target (port scanning — detectable). Passive recon gathers info without touching the target (Google dorking, WHOIS, social media, OSINT — undetectable).

SECTION 7: Penetration Testing / Ethical Hacking

(Q116–Q135)

116. What are the phases of penetration testing? Reconnaissance → Scanning/Enumeration → Gaining Access (Exploitation) → Maintaining Access → Covering Tracks → Reporting.

117. What's the difference between a vulnerability assessment and a penetration test? Vulnerability assessment identifies and lists weaknesses (breadth). Penetration testing actively exploits them to prove real-world impact (depth).

118. What is the difference between black-box, white-box, and grey-box testing? Black-box: no prior knowledge of the system (like a real attacker). White-box: full knowledge (source code, architecture). Grey-box: partial knowledge (e.g., user credentials given).

119. What is a Rules of Engagement (RoE) document? A formal agreement defining scope, timing, systems allowed to be tested, and legal boundaries before a penetration test begins — critical for staying legal.

120. What is the CVE and CVSS system? CVE (Common Vulnerabilities and Exposures) is a standardized identifier for known vulnerabilities. CVSS (Common Vulnerability Scoring System) rates severity (0–10) based on exploitability/impact.

121. What is enumeration in the context of hacking? Actively gathering detailed information about a target (usernames, shares, services, banners) after initial scanning, to identify attack vectors.

122. What is banner grabbing? Connecting to a service (e.g., via Telnet/Netcat) to capture the response banner revealing software name/version, useful for finding known vulnerabilities.

123. What is a buffer overflow? Writing more data to a memory buffer than it can hold, overwriting adjacent memory — can crash a program or be exploited to execute arbitrary code.

124. What is privilege escalation and give one Windows example, one Linux example. Gaining higher access than intended. Windows example: exploiting an unquoted service path. Linux example: exploiting a misconfigured SUID binary.

125. What is lateral movement in an attack? After compromising one system, the attacker moves to other systems within the network to expand access, often using stolen credentials.

126. What is pivoting in penetration testing? Using a compromised host as a launchpad to access other network segments that weren't directly reachable from the attacker's original position.

127. What is a reverse shell vs a bind shell? Reverse shell: the target connects back to the attacker's listener (bypasses inbound firewall rules). Bind shell: the target opens a port and waits for the attacker to connect to it.

128. What is Kerberoasting? An Active Directory attack where an attacker requests service tickets for accounts with Service Principal Names and cracks them offline to recover service account passwords.

129. What is a Golden Ticket attack? A Kerberos attack where an attacker forges a Ticket Granting Ticket using the compromised KRBTGT account hash, granting unlimited domain access.

130. What is Pass-the-Hash? Authenticating to a system using a captured password hash directly, without needing to crack it to plaintext first.

131. What is a payload in exploitation? The actual malicious code delivered after successfully exploiting a vulnerability (e.g., a reverse shell, keylogger).

132. What is fuzzing? Automatically feeding a program random/malformed input to discover crashes, bugs, or vulnerabilities.

133. What is red team vs blue team vs purple team? Red team simulates attackers (offense). Blue team defends and detects (defense). Purple team facilitates collaboration/knowledge-sharing between red and blue.

134. What is OSINT and why is it important in the recon phase? Open-Source Intelligence — gathering publicly available information (LinkedIn, WHOIS, GitHub, social media) about a target without any direct interaction, forming the foundation of both attacks and assessments.

135. What are the legal considerations before doing a penetration test? Written authorization/contract (scope, dates, systems), staying within agreed scope, and NDA compliance — testing without authorization is illegal (unauthorized access/hacking laws).

SECTION 8: Malware & Threats (Q136–Q150)

136. What is malware? Name 5 types. Malicious software designed to harm/exploit systems. Types: virus, worm, trojan, ransomware, spyware, adware, rootkit.

137. Difference between a virus and a worm? A virus needs a host file and human action to spread (e.g., opening an attachment); a worm self-replicates and spreads across networks without user interaction.

138. What is ransomware and how does it typically spread? Malware that encrypts victim files and demands payment for the decryption key; commonly spreads via phishing emails, malicious attachments, or exploiting unpatched vulnerabilities.

139. What is a trojan horse? Malware disguised as legitimate software that, once executed, performs malicious actions in the background.

140. What is a botnet? A network of compromised devices ("bots") controlled remotely by an attacker, often used for DDoS attacks, spam, or crypto-mining.

141. What is a DDoS attack and how is it different from a DoS attack? DoS (Denial of Service) floods a target from a single source; DDoS (Distributed) floods it from multiple sources simultaneously (often via a botnet), making it harder to block.

142. What is a keylogger? Malware or hardware that secretly records keystrokes to steal credentials, messages, and sensitive data.

143. What is spyware vs adware? Spyware secretly monitors user activity and steals data; adware displays unwanted advertisements, sometimes bundled with tracking behavior.

144. What is a logic bomb? Malicious code that lies dormant until triggered by a specific condition (date, event, action), then executes a harmful payload.

145. What is malware analysis, and what's the difference between static and dynamic analysis? Studying malware to understand its behavior. Static analysis examines the code/file without executing it (strings, hashes, disassembly). Dynamic analysis runs it in a controlled sandbox to observe actual behavior.

146. What is a sandbox in the context of malware analysis? An isolated environment where suspicious files can be safely executed and observed without risking the real system/network.

147. What is command and control (C2)? The infrastructure an attacker uses to remotely communicate with and control compromised systems/malware after infection.

148. What is a fileless malware attack? Malware that operates in memory using legitimate system tools (like PowerShell) rather than writing files to disk, making it harder to detect via traditional antivirus.

149. What is an Indicator of Compromise (IoC)? Forensic evidence (unusual file hashes, IPs, domains, registry changes) suggesting a system has been breached.

150. What is the Cyber Kill Chain? A 7-stage model describing an attack's lifecycle: Reconnaissance → Weaponization → Delivery → Exploitation → Installation → Command & Control → Actions on Objectives.

SECTION 9: SOC / Incident Response / SIEM (Q151–Q165)

151. What is a SOC (Security Operations Center)? A centralized team/facility responsible for continuously monitoring, detecting, analyzing, and responding to cybersecurity incidents.

152. What are the phases of Incident Response (NIST/SANS model)? Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned.

153. What is the difference between an event, an alert, and an incident? Event = any observable occurrence in a system. Alert = a notification flagging a potentially suspicious event. Incident = a confirmed security event causing harm/violating policy.

154. What is a false positive vs a false negative in security monitoring? False positive: an alert flags something as malicious when it's actually benign. False negative: a real threat goes undetected — false negatives are more dangerous.

155. What is log correlation and why is it important? Combining logs from multiple sources (firewall, endpoint, server) to identify patterns/attacks that wouldn't be visible from a single log source alone.

156. What is a Playbook/Runbook in incident response? A predefined step-by-step procedure for responding to specific types of incidents (e.g., ransomware, phishing) to ensure consistent, fast response.

157. What is threat hunting? Proactively searching through networks/systems for hidden threats that evaded existing security tools, rather than waiting for alerts.

158. What is the MITRE ATT&CK framework? A globally accessible knowledge base of real-world adversary tactics and techniques, used by defenders to understand, detect, and map attacker behavior.

159. What is chain of custody in digital forensics? Documented, unbroken record of how evidence was collected, handled, and stored — critical for evidence to be admissible/credible.

160. What steps would you take upon detecting a phishing email reported by an employee? Isolate/quarantine the email, check if others received it, analyze headers/links/attachments safely, check if anyone clicked/entered credentials, reset affected accounts, block sender domain, and document findings.

161. What is the first step you should take when you discover a system is compromised? Contain it (e.g., isolate from network) without immediately powering off (which can lose volatile evidence) — follow your incident response plan rather than panicking.

162. What is a Security Operations dashboard typically monitoring? Real-time alerts, network traffic anomalies, failed login attempts, malware detections, and system health across the organization.

163. What is triage in a SOC context? Quickly assessing and prioritizing incoming alerts based on severity/impact to decide what needs immediate attention.

164. What's the difference between Tier 1, Tier 2, and Tier 3 SOC analysts? Tier 1: monitors alerts, initial triage. Tier 2: deeper investigation, incident response. Tier 3: advanced threat hunting, malware analysis, forensic investigation, and mentoring.

165. What is a runbook example for ransomware response? Isolate infected machines from the network immediately → identify the ransomware strain → check backups → do not pay ransom without organizational/legal decision → eradicate and restore from clean backups → conduct root-cause analysis.

SECTION 10: Cloud Security (Q166–Q175)

166. What is the Shared Responsibility Model in cloud security? The cloud provider (AWS/Azure/GCP) secures the underlying infrastructure; the customer is responsible for securing their data, configurations, and access management within it.

167. What is IAM (Identity and Access Management) in cloud platforms? The system controlling who can access what resources and what actions they can perform within a cloud environment.

168. What is a misconfigured S3 bucket and why is it a common breach cause? An AWS storage bucket left publicly accessible due to misconfigured permissions, frequently exposing sensitive data — one of the most common real-world cloud breaches.

169. What is multi-tenancy in cloud computing and its security implication? Multiple customers share the same physical infrastructure; a security implication is ensuring proper isolation so one tenant can't access another's data.

170. What is a CASB (Cloud Access Security Broker)? A security tool/service sitting between users and cloud providers to enforce security policies (visibility, compliance, threat protection) across cloud usage.

171. What is container security and why does Docker need specific attention? Securing containerized applications — Docker containers share the host kernel, so a container escape vulnerability can potentially compromise the host system.

172. What is the difference between IaaS, PaaS, and SaaS from a security perspective? IaaS (e.g., EC2): customer manages OS, apps, data — most responsibility on customer. PaaS (e.g., Heroku): provider manages OS/runtime, customer manages app/data. SaaS (e.g., Gmail): provider manages almost everything, customer manages data/access.

173. What is Zero Trust Architecture? A security model where no user or device is trusted by default, even inside the network perimeter — every request is verified continuously.

174. What is a cloud security posture management (CSPM) tool used for? Continuously scanning cloud environments for misconfigurations and compliance violations against best practices/standards.

175. What are common cloud security misconfigurations to check for? Publicly exposed storage buckets, overly permissive IAM roles, unencrypted data at rest, open security groups (0.0.0.0/0), and disabled logging/monitoring.

SECTION 11: Compliance, Governance & Frameworks (Q176–Q185)

176. What is GDPR and why does it matter? General Data Protection Regulation — an EU law governing how personal data must be collected, processed, and protected, with heavy fines for violations, affecting any company handling EU citizens' data.

177. What is PCI-DSS? Payment Card Industry Data Security Standard — a set of security requirements for any organization that handles credit card transactions.

178. What is ISO 27001? An international standard for establishing, implementing, and maintaining an Information Security Management System (ISMS).

179. What is HIPAA? A US law protecting the privacy and security of patient health information, relevant to healthcare organizations.

180. What is India's IT Act 2000 and its relevance to cybersecurity? India's primary law governing cybercrime and electronic commerce, covering offenses like hacking, data theft, and cyber fraud, and providing legal recognition to digital signatures/records.

181. What is a risk assessment and why is it performed? A structured process of identifying, analyzing, and evaluating risks to determine what security controls are needed and where to prioritize resources.

182. What is a Business Continuity Plan (BCP) vs a Disaster Recovery Plan (DRP)? BCP focuses on keeping the overall business operational during/after a disruption; DRP focuses specifically on restoring IT systems and data after a disaster.

183. What is an audit trail? A chronological record of system activities that allows tracing actions back to their source — critical for accountability and forensic investigation.

184. What is data classification and why is it important? Categorizing data (public, internal, confidential, restricted) based on sensitivity, so appropriate security controls can be applied to each category.

185. What is a security awareness training program and why do companies invest in it? Regular employee training on recognizing phishing, safe practices, and policies — because humans are consistently the weakest link/most common attack vector.

SECTION 12: Practical Scenario-Based Questions (Q186–Q195)

(These are the questions that separate candidates who "studied" from candidates who "understand." Practice explaining your thought process out loud.)

186. Scenario: You find an employee's laptop is running unusually slow and making outbound connections to an unknown IP at 3 AM. What do you do? Isolate the machine from the network immediately (don't shut down yet — preserve volatile memory), check running processes/network connections, capture relevant logs, identify the unknown IP via threat intel, and escalate per the incident response plan.

187. Scenario: A user reports they clicked a link in a suspicious email and entered their password. What are your immediate steps? Force an immediate password reset, check for unusual login activity/sessions on that account, revoke active sessions/tokens, enable/verify MFA, analyze the phishing email/URL, and check if the credentials were used elsewhere (reuse).

188. Scenario: During a pentest, you find a login page vulnerable to SQL injection. Walk through how you'd confirm and exploit it (ethically, in a test environment). Test with a simple payload like ' OR '1'='1' -- in the input field to check for authentication bypass or error-based responses; if

confirmed, use tools like SQLMap in the authorized scope to enumerate the database, always documenting findings for the report rather than causing damage.

189. Scenario: You're asked to check if a website is vulnerable to XSS.

What's your process? Try injecting a harmless test payload like

`<script>alert(1)</script>` into input fields/URL parameters and check if it executes unescaped in the browser response; test both reflected (URL-based) and stored (saved data) contexts.

190. Scenario: You receive an alert that a server has 500 failed login attempts in 5 minutes from one IP. What is happening and what do you do? Likely a brute-force attack; block/rate-limit the source IP at the firewall, verify no successful login occurred among the attempts, check if account lockout policies are working, and add the IP to a blocklist/threat intel feed.

191. Scenario: How would you check if a downloaded file might be malware without opening/running it on your main machine? Calculate its hash (MD5/SHA256) and check it against VirusTotal or malware databases; if needed, examine strings within the file or analyze it in an isolated sandbox/VM, never on the primary machine.

192. Scenario: You're given a pcap (packet capture) file and told "credentials were stolen here — find them." How do you approach it?

Open in Wireshark, filter for `http.request.method == POST` or FTP/Telnet traffic (unencrypted protocols), use "Follow TCP Stream" to view the full data exchange, and look for plaintext username/password fields.

193. Scenario: A junior teammate wants to test a company's website for vulnerabilities they found via Google. What do you tell them? Explain that testing without written authorization is illegal under cyber laws (e.g., IT Act 2000), regardless of good intentions — they should report responsibly via the company's bug bounty program or official disclosure channel instead.

194. Scenario: You need to explain a critical vulnerability you found to a non-technical manager. How do you communicate it? Avoid jargon; explain business impact in plain terms (e.g., "an attacker could access customer credit

card data without a password"), state severity/likelihood, and give a clear, prioritized recommendation for fixing it.

195. Scenario: You're asked to secure a newly built web application before launch. What's your checklist approach? Run a vulnerability scan, check for OWASP Top 10 issues, review authentication/session management, ensure HTTPS/secure headers are configured, check for exposed secrets/default credentials, validate input sanitization, and perform a final penetration test before go-live.

SECTION 13: HR / Behavioral Questions for Interns (Q196–Q200)

(Almost every internship interview — even purely technical ones — ends with these. Have real, honest, specific answers ready.)

196. Why do you want to pursue a career in cybersecurity? Give a genuine, specific reason (a project, a CTF you solved, curiosity about how systems break) rather than a generic "I love technology" answer — specificity shows real interest.

197. Tell me about a project or CTF (Capture The Flag) challenge you've worked on. Walk through it like a story: what the challenge was, what tools/approach you used, what obstacle you hit, and how you solved it — this demonstrates real hands-on thinking, not memorized theory.

198. How do you stay updated with the latest cybersecurity trends/vulnerabilities? Mention real sources you actually follow: TryHackMe/HackTheBox, security blogs, Twitter/X security researchers, CVE

feeds, YouTube channels (e.g., NetworkChuck, John Hammond), or a subreddit/Discord community.

199. Describe a time you had to learn something technical quickly on your own. Use a real example (a tool, a language, a platform) and focus on your process — how you researched, practiced, and applied it — since self-learning ability is exactly what internships test for.

200. Where do you see yourself in this field in 2–3 years? Be honest and grounded — e.g., "I want to grow from an internship into a SOC analyst or junior pentester role, build a strong practical skill set, and eventually specialize in [web app security / cloud security / incident response]" — shows direction without sounding rehearsed.

Final Notes for Practice

- **Practical proof matters more than answers.** If you can show even a basic home-lab demo (scanning a VM with Nmap, intercepting your own traffic in Burp Suite, analyzing a sample pcap in Wireshark), that alone can push you from a ₹5k unpaid internship into a ₹30k–₹50k paid one.
- **Build a portfolio while practicing these:** a GitHub with write-ups of TryHackMe/HackTheBox rooms you've solved is one of the strongest signals for interviewers at this level — more than certificates.
- **For the ₹50k–₹1L+ and job-level (~₹2L package) interviews,** expect deeper follow-ups on any answer above ("okay you said XSS — now show me how you'd find it on a live test site" or "walk me through your Nmap scan output line by line"). Practice explaining your reasoning, not just facts.
- Revisit Sections 6, 7, 9, and 12 (tools, pentest, SOC, scenarios) the most — these are what interviewers actually probe for practical hiring decisions.

Good luck — practice this out loud, section by section, a few times a week rather than cramming once.

